



追加機能における設計判断 と意図的な対象外事項

1. この文書の目的

本追加機能は、実務システムとして理想的なすべての対策を実装することではなく、教科書で学習した内容を使って段階的に実装できることを重視している。

そのため、実務では通常追加する対策の一部を、意図的に必須範囲から外している。本書では、その理由と、将来追加する場合の位置付けを整理する。

2. URL直接入力による操作制限

実務システムでは、画面からボタンを隠すだけでなく、URL直接入力やHTTPリクエストによる不正な操作もサーバー側で防ぐべきである。Controllerでログイン状態と権限を確認する方法、Interceptorを使う方法、Spring Securityを使う方法などがある。

ただし、本教材ではInterceptor、AOP、Spring Securityを教科書で扱っていない。Controllerに個別の権限確認を追加すると、受講者にとって「画面の表示制御」と「サーバー側のアクセス制御」の違いを同時に理解する必要があり、学習範囲を超えてしまう。

このため、今回の必須実装ではThymeleafによるメニュー・ボタンの表示制御までを扱い、URL直接入力の制限は実装しない。これは制限の必要性を否定するものではなく、教科書外の発展オプションとして残す判断である。

将来この機能を追加する場合は、画面表示の条件をそのままセキュリティ対策と見なさず、ControllerまたはInterceptorでログイン状態・管理者権限・本人判定を確認する。

3. 在籍社員の絞り込み位置

実務では、在籍社員だけを一覧に出すという業務ルールをServiceまたはRepositoryで絞り込む方法がある。データを取得する段階で対象を限定できるため、画面ごとに条件を書かなくてよい利点がある。

一方で、本教材の標準実装は、共通機能の `findAll()` をそのまま利用し、Thymeleafの `th:if` で退職者の行を表示しない方法とする。これは共通機能で学習した書き方をそのまま使え、初学者が一覧表示と条件分岐の関係を確認しやすいためである。

したがって、在籍社員取得用のServiceメソッドや参考ソースコードは提供しない。教材内では表示側での絞り込みに統一し、Serviceで絞り込む方法は発展的な別テーマとして扱う。

なお、通常検索では退職者を検索結果に含めない。検索処理の絞り込みと、一覧画面での行の表示制御は、目的と実装場所が異なる。

また、本教材では、在籍社員が0人で退職者だけが残る状態は通常操作の対象外とする。管理者本人は画面上で退職処理できないため、初期データと通常操作では少なくとも管理者1人が在籍する。このため、社員一覧の0件メッセージは、`findAll()` の取得結果が0件の場合だけを扱い、退職者だけが残る場合の表示は考慮しない。

4. 権限の登録・変更

権限をWeb画面から変更できるようにすると、一般ユーザーが自分や他社員を管理者に変更できる危険がある。実務でも、権限変更を許可する場合は、専用の管理機能、厳格な権限確認、操作履歴などを組み合わせて扱うべきである。

本演習では、社員番号 `10001` だけを管理者とし、DBの `role = 1` を固定値として登録する。それ以外の社員は `role = 0` とする。登録画面・変更画面には権限入力欄を設けず、Web画面から権限を登録・変更する機能は提供しない。

これは省略ではなく、Web画面で権限を変更させないための仕様である。
Serviceでも新規登録時は一般ユーザーかつ在籍、更新時はDBに登録済みの権限と退職状態を維持する。

5. パスワードの桁数

登録時の入力条件とログイン時の条件が異なると、登録できたパスワードでログインできない不具合につながる。

本追加機能では、独自の桁数ルールを追加せず、共通機能の入力仕様に合わせて4文字以上16文字以下に統一する。共通機能では、DB定義とEntityの列容量は20文字だが、画面入力には4文字以上16文字以下に制限している。列容量は保存できる最大長、入力仕様は画面から受け付ける値の範囲を表すため、本教材では入力仕様を正とする。

6. 自動テストの範囲

追加機能については、ログイン処理をControllerテストで確認し、Web画面から権限・退職状態を変更できないことをService単体テストで確認する。

URL直接入力の制限は発展オプションであり、現時点では実装しないため、その制限を前提とするControllerテストも含めない。発展オプションを実装した段階で、未ログイン・一般ユーザー・管理者それぞれのURLアクセスを確認するテストを追加する。

7. スクリーンショットの扱い

追加機能はチームで段階的に分担して実装する前提である。そのため、設計書のスクリーンショットには、すべての追加機能を完成させた最終画面だけでなく、各追加機能を加えた時点の画面も含める。

これは画面の不整合ではなく、どの段階で何が追加されるかを学習者に示すための意図的な構成である。ただし、各スクリーンショットは、その説明で示す実装段階の実画面と一致させる。今回、一般ユーザーが社員一覧を直接表示し

た画面も、URL直接入力を制限しない現仕様に合わせて更新している。

8. まとめ

本追加機能では、学習済みのThymeleaf、Service、Controller、Entityを使って理解できる範囲を必須とする。

- 画面上の権限表示制御は必須とする。
- Web画面からの権限変更は許可しない。
- URL直接入力の制限は、必要性を明記したうえで発展オプションとする。
- 在籍社員の一覧表示は、教材ではThymeleafで行う。
- 共通機能と矛盾する入力規則は作らない。

この区分により、教材としての分かりやすさを保ちながら、実務で追加すべき対策も見失わない設計とする。